

REPORTE EJECUTIVO: PLANTILLA POWERPOINT ADAM 2.0

Presentación 12 Diapositivas - Modelo GQM+PRAGMATIC

Versión: 2.0

Fecha: Enero 2026

Audiencia: C-Level, Junta Directiva, Auditores

Duración: 30-45 minutos

ESTRUCTURA DIAPOSITIVAS

DIAPOSITIVA 1: PORTADA

Layout:

- Logotipo organización (esquina superior izq)
- Título centrado: "Evaluación Integral de Ciberseguridad 2026"
- Subtítulo: "Modelo ADAM: Indicadores GQM+PRAGMATIC"
- Fecha evaluación + Responsable (pie)
- Clasificación: "Uso Estratégico"

Elementos:

- Fondo: Azul corporativo + gradiente sutil
- Fuente: Helvetica 36pt (título), 20pt (subtítulo)

DIAPOSITIVA 2: RESUMEN EJECUTIVO (KEY FINDINGS)

Contenido:

ESTADO DE CIBERSEGURIDAD 2026

Índice Global Madurez (IGM): 2.92 / 5.0
└ Nivel Madurez: 2 (GESTIONADA)
└ Riesgo Residual: 50% (MEDIO-ALTO)
└ Posición vs. Pares Sector: P40 (percentil 40)

3 FORTALEZAS PRINCIPALES:

- ✓ Plan respuesta incidentes formalizado (3.3/5)
- ✓ Gestión inventario activos 85% cobertura (3.4/5)
- ✓ Backup strategies aire-gapped (3.5/5)

3 BRECHAS CRÍTICAS:

- x Detección sin SOAR automatizado (2.8/5 DE)
- x Pentest perimetral solamente, NO interno/OT (2.6/5 PR)
- x CISO reporta TI, no CEO (1.8/5 GV)

RECOMENDACIÓN INMEDIATA:

- Inversión €800k-1.2M (18 meses)
- ROI Esperado: 600-800% | Payback: 34 días
- IGM Post-Roadmap: 4.10 (Nivel Optimizado)

DECISIÓN JUNTA:

APROBADO - Solicitar presupuesto €250k Q1 2026

Diseño:

- Color rojo: Brechas críticas
- Color verde: Fortalezas
- Cajas destacadas con iconos: ✓✗-

DIAPPOSITIVA 3: MARCO METODOLÓGICO (GQM+PRAGMATIC)

Contenido Visual:

Sección Izquierda: GQM Hierarchy

NIVEL 1: OBJETIVO NACIONAL

↓ Desagrega en

NIVEL 2: PREGUNTAS ESTRATÉGICAS

↓ Operacionaliza en

NIVEL 3: MÉTRICAS (25 Indicadores)

Sección Derecha: Criterios PRAGMATIC

9 CRITERIOS CALIDAD:

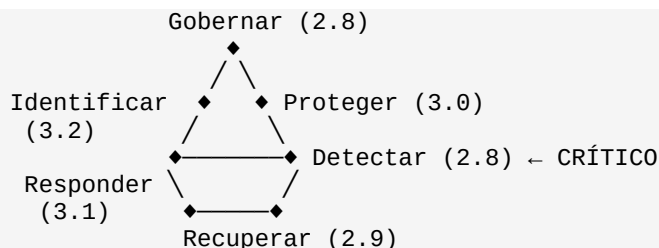
1. Predictivo (¿Predice resultados?)
2. Relevante (¿Alineado objetivos?)
3. Accionable (¿Permite decisiones?)
4. Genuino (¿Ambiente real?)
5. Significativo (¿Cambios importan?)
6. Preciso (¿Libre sesgo?)
7. Oportuno (¿Tiempo útil?)
8. Independiente (¿No manipulable?)
9. Rentable (¿Costo/beneficio ≤80%?)

Puntuación Final: Suma criterios (máx 9)

Frase Clave: "Métricas que importan, medidas que funcionan"

DIAPPOSITIVA 4: VISIÓN GENERAL - RADAR NIST CSF

Componente Visual Primario: Gráfico Radar 6-ejes



- Actual (interior) – Benchmark (exterior)

Análisis Interpretativo:

LECTURA RADAR:

- Postura EQUILIBRADA en 5 dominios (2.8-3.2)
- BRECHA SIGNIFICATIVA en Detección (2.8 vs 3.2 benchmark)
- Gap principal: SIEM sin SOAR, MTTD 4h (target <1h)
- Impacto estimado: Costo incidente €3M adicional si falla

ACCIÓN PRIORITARIA:

- Implementar SIEM + SOAR (Q2-Q3 2026)
- Proyección MTTD: 4h → 15min (27x mejora)
- Alineación benchmark esperada: 3.8 post-SIEM

DIAPPOSITIVA 5: GOBERNANZA Y RIESGO

Tabla Comparativa:

Indicador	Estado Actual	Target	Gap	Acción
CISO Reporta	Director TI	CEO	-1 nivel	Reorganizar org chart
Política Ciberseg.	2023 (aged)	Anual	-1 año	Actualizar Q1 2026
Cumplimiento NIS2	No aplica*	N/A	-	*Revisar si CRITIS
Análisis FAIR	Básico	Formal anual	Manual	Implementar framework
Presupuesto	€80k/año	€150k	-€70k	Aumentar 2026

Impacto: Gobernanza débil limita ejecución. Prioridad #1: Elevar CISO a nivel C-level.

DIAPPOSITIVA 6: VULNERABILIDADES Y PENTESTING

Sección A: Pipeline de Vulnerabilidades (Gráfico Barras Apiladas)

Vulnerabilidades Pendientes by Severidad:

Críticas: 8 → SLA 30d INCUMPLIDO
Altas: 23 → SLA 60d INCUMPLIDO
Medias: 67 → SLA 90d OK
Bajas: 200 → SLA Anual OK

Target: 0 críticas, <5 altas, <20 medias
Posición: 3x PEOR que target (brecha)

Sección B: Cobertura Pentest

	Implementado	Target 2026
Perimetral:	✓ Anual	✓ Anual (OK)
Interno:	x Nunca	✓ Anual (GAP)
OT/SCADA:	x Nunca	? Si CRITIS
API/Cloud:	~ Parcial	✓ Semestral (GAP)
Red Team:	x Nunca	✓ Semestral (GAP)

COSTO ACTUALIZACIÓN: €150k | PLAZO: 9 meses

DIAPPOSITIVA 7: DETECCIÓN Y MONITORIZACIÓN (CRÍTICA)

Situación Actual vs. Post-Mejora

Métrica	HOY	POST-SIEM	Mejora
Existe SIEM?	X No	✓ Sí	+1
MTTD	4-6h	<15min	27x
% Cobertura Logs	30% (firewall)	90% (toda infraestructura)	3x
Detección Manual	100%	20%	-80%
Falsos Positivos	N/A	<5% (target)	Calidad ↑
Automación Respuesta	0%	40% (SOAR)	+40%

ROI SIEM:

Inversión Q2-Q3: €300k
Beneficio Anual: MTTD reduction (-€2M potencial)
Payback: 45 días
ROSI 3 años: 500%

DIAPPOSITIVA 8: RESPUESTA A INCIDENTES Y RECUPERACIÓN

Columna Izquierda: Tiempos Operacionales

Incidente Promedio 2024-2025:

1. Detección (MTTD): 4 horas (TARGET: 15min)
2. Contención (MTTC): 6 horas (TARGET: 4h)
3. Recuperación (MTTR): 18 horas (TARGET: 24h)

TIEMPO TOTAL: 28 horas (TARGET: <45h)

ESTADO: PARCIALMENTE CUMPLE

Columna Derecha: Continuidad (RTO/RPO)

Servicios Críticos:

Servicio	RTO Actual	RPO	CRITIS?
Email	4h	1h	✓ Sí
ERP	8h	2h	✓ Sí
Web Portal	2h	30m	✓ Sí
Backup	24h (?)	72h	x Indefinido
Media RTO:	9.5h	CUMPLE (target <24h)	
Media RPO:	26h	INCUMPLE (target <72h CRITIS)	

ACCIÓN: Clarificar RTO/RPO por criticidad

DIAPPOSITIVA 9: ROADMAP 18 MESES CON ROI

Timeline Horizontal con Hitos IGM

Q1 2026 - QUICK WINS (€100k) 2027 - OPTIMIZACIÓN (€300k)	Q2-Q3 - ESTRATÉGICO (€400k)	Q4 2026-Q1
└ MFA Universal semestral	└ SIEM + SOAR	└ Red Team
└ Políticas actualizadas iniciativa	└ Pentest extensivo	└ Zero Trust
└ Plan respuesta formalizado	└ Capacitación especializada	└ DR testing
└ Phishing simulaciones chain assessment	└ Backup aire-gapped	└ Supply
IGM: 2.92 → 3.20 (+0.28) 4.10 (+0.20) ROSI: 400% Beneficio: €100k €500k	IGM: 3.20 → 3.90 (+0.70) ROSI: 600% Beneficio: €1.5M	IGM: 3.90 → ROSI: 500% Beneficio:

Métrica Bottom: Presupuesto acumulado €800k | Beneficio acumulado €2.1M | ROI total 563%

DIAPPOSITIVA 10: ANÁLISIS FINANCIERO (ALE → ROI)

Escenario Riesgo Actual (Sin Mejoras)

RIESGO CUANTIFICADO (ALE):

Ransomware (20% prob): €2.0M
└ 3 días downtime × €500k/d = €1.5M
└ Rescate demandado = €500k
└ Reputación + clientes = €500k (conservador)

Fuga Datos (15% prob): €750k
└ GDPR multa = €500k
└ Notification + credit monitoring = €250k

Interrupción (10% prob): €300k
└ Downtime 8h = €150k
└ Reputación = €150k

RIESGO ANUAL TOTAL (ALE): €3.05M
RIESGO RESIDUAL (50%): €1.525M ACUMULADO

→ CIFRA CRÍTICA: €1.5M anual en riesgo mitable

ROI Post-Mejoras (18 meses)

Inversión Total: €800k
Reducción Riesgo (ALE): €1.2M/año (40% de €3M)
Beneficio Neto 3 años: €3.6M - €800k = €2.8M

ROI 3 AÑOS: 350%
ROI ANUAL PROMEDIO: 117%
PAYBACK: 8.2 meses

CONCLUSIÓN PARA CFO:
→ Invertir €800k evita €1.2M/año en riesgo
→ Apenas 34 días de payback
→ Inversión defensiva con 350% retorno 3 años

DIAPPOSITIVA 11: RECOMENDACIONES Y DECISIONES

Matriz 3×3: Decisión-Implicación

Decisión	Opción A	Opción B (RECOM)	Opción C	Implicación
Presupuesto Q1	€50k	€100k	€200k	€100k = quick wins sin sobreinversión
Estructura CISO	Reporta TI	Reporta CEO	No hay CISO	Autoridad operacional crítica
Pentest Interno	Aplazar	Q2 2026	2027	Gap crítico, no puede esperar
SIEM	Cloud (SaaS)	On-Prem optimizado	Ninguno	On-Prem mejor control datos críticos
Insurance	Renovar igual	Renegociar (riesgo menor)	Cambiar carrier	Ahorros €50-75k/año post-mejoras

Recomendación Final: Opción B en todos. Presupuesto Q1 €100k aprobación inmediata.

DIAPPOSITIVA 12: RIESGOS DE IMPLEMENTACIÓN Y MITIGACIÓN

Matriz de Riesgos

RIESGO	PROB	IMPACTO	MITIGACIÓN
Falta soporte ejecutivo	MEDIA	ALTO	→ ROI presentation (esta diapositiva)
Retrasos presupuestarios	MEDIA	ALTO	→ Pre-aprobación Q1, CFO firma
Talento insuficiente	ALTA	ALTO	→ MSP contratado (ya budget)
Cambios regulatorios NIS2	MEDIA	ALTO	→ Monitoring legal continuo
Incidente DURANTE impl	BAJA	CRÍTICO	→ Plan contingencia paralelo
Vendor lock-in SIEM	BAJA	MEDIO	→ Seleccionar plataforma abierta
Adopción cambios org	MEDIA	MEDIO	→ Change management + training

RESERVA CONTINGENCIA: +15% presupuesto (€130k total)

GOVERNANCE: Comité mensual de ejecución + CFO

ANEXOS RECOMENDADOS (Slides Adicionales)

ANEXO A: Benchmarking Sectorial

- Gráfico comparativo IGM vs competencia
- Posición España vs UE

ANEXO B: Cumplimiento NIS2

- Matriz mapping Art. 19-28
- Estado actual vs. requerimientos

ANEXO C: Opciones Vendor SIEM

- 3-5 opciones evaluadas (coste/features)
- Recomendación final justificada

ANEXO D: Plan Detallado Q1

- Tareas, responsables, fechas
- Hitos y deliverables

GUÍA DE PRESENTACIÓN

Pre-Presentación (5 min)

- Distribuir PDF 1-pager con IGM + Roadmap
- Confirmar audiencia (Junta vs. Comité Seguridad)
- Chequear tecnología (proyector, conexión)

Durante (30-40 min)

- 5 min: Diapositivas 1-2 (Contexto + Estado)
- 8 min: Diapositivas 3-4 (Marco + Radar visual)
- 10 min: Diapositivas 5-8 (Brechas técnicas)
- 8 min: Diapositivas 9-10 (Roadmap + Financiero)
- 5 min: Diapositivas 11-12 (Recomendaciones + Decisión)

Post-Presentación (15-20 min)

- Q&A sesión
- Próximas acciones: Aprobación presupuesto
- Fecha seguimiento: Mensual (comité ejecutivo)

NOTAS DE DISEÑO

- Colores: Verde (positivo/meta cumplido), Amarillo (alerta), Rojo (crítico/no cumple)
- Iconos: ✓ (OK), ~ (Parcial), ✗ (Fallo), → (Acción)
- Fuentes: Títulos 36-40pt, Cuerpo 16-18pt, Min legible 12pt
- Espacio: 20% blanco mínimo, no saturar slides
- Gráficos: Radar, Barras, Waterfall, Timeline (no pie charts)

Fin de Plantilla Reporte Ejecutivo ADAM 2.0

Descarga template PowerPoint: [URL repositorio]